

# Document 13 — Information Security Policy (RTS security requirements)

|                   |                                                                                                                                                                 |
|-------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Operator</b>   | [COMPANY NAME], trading as PlayStake                                                                                                                            |
| <b>Owner</b>      | [COMPLIANCE LEAD NAME], Head of Compliance, as Information Security Officer until a dedicated role is appointed; [ENGINEERING LEAD NAME] for technical controls |
| <b>Version</b>    | 0.1 — draft for licence application                                                                                                                             |
| <b>Review</b>     | Annually; after any security incident; after the annual security audit                                                                                          |
| <b>Relates to</b> | RTS security requirements (ISO/IEC 27001:2022 controls named by the Commission); LCCP 15.2.1 key events; UK GDPR; Documents 08, 11, 14                          |

Draft prepared from the platform as built on 30 September 2026. Status reflects what exists in the code and configuration today. "Partial" and "Planned" items are listed in §6 with owners. [BRACKETS] must be completed before submission.

## 1. Policy statement

PlayStake protects customer funds, customer data and the integrity of its games. We base our information security management on ISO/IEC 27001:2022 and meet, as a minimum, the controls the Commission's RTS security requirements name. The controls apply to every system that handles customer data, money or game outcomes: the web and worker services, the database, the admin console, and the suppliers in Document 08.

We commit to:

- a named owner for information security with authority to stop a release or suspend a service;
- controls proportionate to risk, reviewed at least annually;
- an independent security audit every year, the first within six months of licence grant (Document 11 §7);
- reporting security incidents to the Commission and the ICO when required (Document 14).

## 2. Scope

| In scope                                                   | Notes                                        |
|------------------------------------------------------------|----------------------------------------------|
| Web service, worker service, PostgreSQL, Redis (Railway)   | All customer data, the ledger and game logic |
| Admin console and staff accounts                           | Privileged access                            |
| Source code, CI and deployment pipeline (GitHub → Railway) | Integrity of released software               |

| In scope                                                                       | Notes                                   |
|--------------------------------------------------------------------------------|-----------------------------------------|
| Suppliers handling customer data (Stripe, Resend, Sentry, GAMSTOP, IBAS, eIDV) | Through supplier management (5.19–5.23) |
| Staff devices used for administration                                          | Endpoint controls (8.1)                 |

### 3. Key technical safeguards

- **Money:** double-entry ledger; only `transfer()` changes balances; sufficient-funds check in the same SQL statement as the debit; idempotency keys; ledger entries append-only by database trigger; daily automated audit of every account and transaction.
- **Games:** every outcome decided on the server with a CSPRNG; hidden information never sent to clients; append-only game event log.
- **Identity and access:** passwords hashed with bcrypt (cost 12); sign-in rate limits and logout; session tokens random, stored only as SHA-256 hashes, 7-day lifetime and 30-minute idle timeout; staff require TOTP two-factor authentication (enforced in production); role-based access checked on every admin route.
- **Data protection:** identity documents encrypted with AES-256-GCM; Kick OAuth tokens encrypted under a separate key; card data never touches PlayStake (Stripe Elements); all traffic over HTTPS with HSTS.
- **Web application:** input validation (Zod) on all API routes; Content-Security-Policy; framing blocked except for the embeddable widget; `nosniff`, strict referrer policy, restrictive permissions policy; identity-document responses sandboxed and never cached.
- **Integrations:** Stripe and Kick webhooks verified by signature; outbound webhooks to developers signed with HMAC-SHA256; constant-time comparison of secrets.
- **Audit:** every privileged staff action (including each view of an identity document) is written to an append-only admin audit log with actor, target, change and IP address.

## 4. Control mapping — ISO/IEC 27001:2022

Status: **In place** — implemented and evidenced; **Partial** — some of the control exists, gap in §6; **Planned** — not yet in place.

### 4.1 Organisational controls

| Control                                       | How PlayStake meets it                                                                                                          | Status                           |
|-----------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------|----------------------------------|
| 5.1 Policies for information security         | This policy, approved by the board and reviewed annually                                                                        | Partial — board approval pending |
| 5.10 Acceptable use of information and assets | Staff acceptable-use rules: admin console only from managed devices, no customer data in personal tools, no sharing of accounts | Planned — write and sign         |
| 5.15 Access control                           | Roles (PLAYER, DEVELOPER, ADMIN, plus approved referee status) enforced server-side on every route; least privilege for staff   | In place                         |

| Control                                                     | How PlayStake meets it                                                                                                                                             | Status                                 |
|-------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------|
| 5.16 Identity management                                    | One named account per person; no shared admin accounts; accounts closed on leaving                                                                                 | In place (process)                     |
| 5.17 Authentication information                             | bcrypt password hashing; TOTP 2FA for staff; secrets only in Railway environment variables, never in code                                                          | In place                               |
| 5.18 Access rights                                          | Staff access granted by the Head of Compliance, recorded, and reviewed quarterly; infrastructure (Railway, GitHub, Stripe) access reviewed at the same time        | Partial — first review to schedule     |
| 5.19 Information security in supplier relationships         | Suppliers assessed before use (Document 08 §4)                                                                                                                     | Partial — assurance reports to collect |
| 5.20 Addressing security within supplier agreements         | DPA's and security terms in each supplier contract                                                                                                                 | Partial — confirm DPA's on file        |
| 5.21 Managing security in the ICT supply chain              | Dependabot updates; CI dependency audit fails on critical vulnerabilities; malware scan on every push and weekly; lockfile-pinned installs ( <code>npm ci</code> ) | In place                               |
| 5.22 Monitoring and review of supplier services             | Annual supplier review; incident notifications from suppliers assessed under Document 14                                                                           | Planned                                |
| 5.23 Information security for use of cloud services         | Railway project access limited to named staff with 2FA; region and backups recorded                                                                                | Partial — region, backups (§6)         |
| 5.24 Incident management planning and preparation           | Document 14                                                                                                                                                        | In place (document)                    |
| 5.25 Assessment and decision on information security events | Triage in Document 14 §3                                                                                                                                           | In place (document)                    |
| 5.26 Response to information security incidents             | Document 14 §4                                                                                                                                                     | In place (document)                    |
| 5.28 Collection of evidence                                 | Append-only audit logs, ledger and game events; log export and preservation steps in Document 14                                                                   | Partial — log retention (§6)           |
| 5.35 Independent review of information security             | Annual independent security audit; quarterly review by external compliance adviser                                                                                 | Planned                                |

## 4.2 People controls

| Control                                                        | How PlayStake meets it                                                                                                     | Status                    |
|----------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------|---------------------------|
| 6.3 Awareness, education and training                          | Security training on joining and annually, recorded with safer-gambling and AML training (Master Manual §5.4)              | Planned                   |
| 6.5 Responsibilities after termination or change of employment | Leaver checklist: close admin account, remove Railway/GitHub/Stripe access, rotate any shared secrets the person could see | Planned — write checklist |

| Control                                  | How PlayStake meets it                                                                                       | Status                                |
|------------------------------------------|--------------------------------------------------------------------------------------------------------------|---------------------------------------|
| 6.7 Remote working                       | Administration only from managed devices with disk encryption and screen lock, over HTTPS with 2FA           | Partial — device standard to document |
| 6.8 Information security event reporting | Anyone who spots a possible incident reports it at once to the Information Security Officer (Document 14 §2) | In place (document)                   |

### 4.3 Physical controls

PlayStake operates no data centre or office servers; physical security of hosting is provided by Railway and its infrastructure providers.

| Control                                     | How PlayStake meets it                                                                             | Status                      |
|---------------------------------------------|----------------------------------------------------------------------------------------------------|-----------------------------|
| 7.8 Equipment siting and protection         | Hosting provider's data-centre controls, evidenced by its assurance report                         | Partial — report to collect |
| 7.10 Storage media                          | No customer data on removable media; exports only when necessary, encrypted, and deleted after use | Planned — write rule        |
| 7.14 Secure disposal or re-use of equipment | Staff devices wiped before disposal or re-use; provider handles hosting media                      | Planned — write rule        |

### 4.4 Technological controls

| Control                            | How PlayStake meets it                                                                                                                                                                            | Status                                                          |
|------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------|
| 8.1 User endpoint devices          | Staff devices: full-disk encryption, OS updates, screen lock, password manager                                                                                                                    | Partial — to document and check                                 |
| 8.2 Privileged access rights       | ADMIN role limited to named staff; 2FA enforced; all admin actions audit-logged; production database access limited to named engineers through Railway                                            | In place                                                        |
| 8.3 Information access restriction | Customers see only their own data; bet and game data limited to participants; identity documents only to admins, streamed decrypted per request and logged                                        | In place                                                        |
| 8.5 Secure authentication          | Rate-limited sign-in and logout; session tokens hashed; 30-minute idle timeout; 7-day absolute lifetime; staff 2FA                                                                                | In place                                                        |
| 8.7 Protection against malware     | CI malware scan; dependency audit; no file execution from uploads; identity documents served sandboxed with <code>nosniff</code> ; removed a disguised HTML file from public assets (30 Sep 2026) | In place                                                        |
| 8.13 Information backup            | Railway PostgreSQL backups                                                                                                                                                                        | <b>Planned — confirm enabled, set retention, test a restore</b> |
| 8.15 Logging                       | Structured JSON logs from web and worker; admin audit log; ledger and game event logs; Sentry error reports                                                                                       | Partial — log retention period and access to be set             |

| Control                                                          | How PlayStake meets it                                                                                                                                                                                             | Status                                                                                                           |
|------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------|
| 8.17 Clock synchronisation                                       | Hosts synchronised by the provider; the application records times in UTC                                                                                                                                           | Partial — database columns store times without time zone (UTC by convention); migrate to <code>timestampz</code> |
| 8.18 Use of privileged utility programs                          | Direct database access (Prisma Studio, psql) only for named engineers, for a recorded reason; money never changed outside <code>transfer()</code>                                                                  | Partial — record usage                                                                                           |
| 8.20 Networks security                                           | Database and Redis reachable only on Railway's private network [CONFIRM no public database proxy]; all public traffic over HTTPS                                                                                   | Partial — confirm                                                                                                |
| 8.21 Security of network services                                | TLS on all endpoints; HSTS; webhook signatures                                                                                                                                                                     | In place                                                                                                         |
| 8.22 Segregation of networks                                     | Production separate from development and CI; services communicate over Railway's private network                                                                                                                   | Partial — confirm                                                                                                |
| 8.24 Use of cryptography                                         | AES-256-GCM for identity documents and OAuth tokens with separate keys; bcrypt; SHA-256 token hashes; HMAC-SHA256 webhook signing; TLS. Keys held only in the hosting environment; key rotation procedure to write | Partial — rotation procedure                                                                                     |
| 8.25 Secure development life cycle                               | All changes in Git; CI lint, type check, tests, dependency audit and malware scan before release; change classes and sign-off (Document 11 §5)                                                                     | In place                                                                                                         |
| 8.26 Application security requirements                           | Server-side authorisation on every route; identity from session only, never the request body; input validation; idempotency on money routes                                                                        | In place                                                                                                         |
| 8.27 Secure system architecture and engineering principles       | Ledger as trust boundary; server-authoritative games; append-only records; fail-closed eligibility gate                                                                                                            | In place                                                                                                         |
| 8.29 Security testing in development and acceptance              | Automated tests for authorisation and exploit paths (e.g. forged sessions, client-declared results); independent penetration test before launch and annually                                                       | Partial — penetration test not yet done                                                                          |
| 8.30 Outsourced development                                      | None at present; any future outsourced development under the same CI and review                                                                                                                                    | In place                                                                                                         |
| 8.31 Separation of development, test and production environments | Local and CI environments use their own databases; production secrets never in development                                                                                                                         | In place                                                                                                         |
| 8.32 Change management                                           | Document 11 §5                                                                                                                                                                                                     | In place                                                                                                         |
| 8.33 Test information                                            | Tests create their own synthetic data; production data is never copied into test                                                                                                                                   | In place                                                                                                         |

## 5. Known residual risks (accepted, with review date)

| Risk                                                                                                                                                           | Why accepted for now                                                                                                                 | Review                           |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------|----------------------------------|
| High-severity advisories in the Prisma CLI toolchain ( <code>@prisma/dev</code> , <code>mysql2</code> , <code>deepmerge-ts</code> , <code>find-my-way</code> ) | Development/migration tooling, not used to serve requests; the only fix offered is a major-version downgrade. Tracked by Dependabot. | Monthly                          |
| Content-Security-Policy allows inline scripts                                                                                                                  | Needed by the Next.js runtime; move to per-request nonces                                                                            | Before launch                    |
| Rate limits held in each web process's memory                                                                                                                  | Correct with one web instance; must move to Redis before scaling out                                                                 | Before running two web instances |

## 6. Gaps and actions

| #  | Action                                                                                             | Control                         | Owner              | Due                   |
|----|----------------------------------------------------------------------------------------------------|---------------------------------|--------------------|-----------------------|
| 1  | Confirm Railway backups are enabled, set retention, and test a restore; record the result          | 8.13                            | Engineering        | Before launch         |
| 2  | Set log retention and access; export logs to durable storage                                       | 8.15, 5.28                      | Engineering        | Before launch         |
| 3  | Commission an independent penetration test and fix findings                                        | 8.29                            | Head of Compliance | Before launch         |
| 4  | Appoint the annual security auditor; first audit within 6 months of grant                          | 5.35                            | Head of Compliance | Grant + 6 months      |
| 5  | Write acceptable use, leaver checklist, device standard, media and disposal rules; staff sign them | 5.10, 6.5, 6.7, 7.10, 7.14, 8.1 | Head of Compliance | Application           |
| 6  | Collect supplier assurance reports and DPAs                                                        | 5.19–5.23, 7.8                  | Head of Compliance | Application           |
| 7  | Migrate timestamp columns to <code>timestampz</code>                                               | 8.17                            | Engineering        | Within 3 months       |
| 8  | Key rotation procedure for encryption and signing keys                                             | 8.24                            | Engineering        | Before launch         |
| 9  | Move rate limiting to Redis                                                                        | 8.5                             | Engineering        | Before scaling        |
| 10 | Nonce-based CSP                                                                                    | 8.26                            | Engineering        | Before launch         |
| 11 | Confirm database and Redis are not publicly reachable                                              | 8.20, 8.22                      | Engineering        | Application           |
| 12 | Quarterly access review of admin, Railway, GitHub and Stripe accounts                              | 5.18                            | Head of Compliance | Quarterly from launch |

| Version | Date              | Change      |
|---------|-------------------|-------------|
| 0.1     | 30 September 2026 | First draft |